

Quantum Safe & Cryptography Management Hands-on, an IBM TechXchange Workshop

Ihr Ansprechpartner



Vladimir Atanaskovik
VLADIMIR@de.ibm.com



Piotr Henzel
Piotr.Henzel@ibm.com



Justus Reich
jreich@de.ibm.com



Michael Hagebölling
Michael.Hageboelling@de.ibm.com

Agenda

14:30 - 14:45	Willkommen & Einführung
14:45 - 15:30	Quantum Safe Readiness & regulatorische Anforderungen
15:30 - 16:00	Hands-on: Krypto-Agilität
16:00 - 16:30	Hands-on: Quantum-Safe mit IBM Bob
16:30 - 17: 00	Kurze Erholungspause
17:00 - 17:30	IBM Guardium Cryptography Manager: Cryptography Discovery, Risikomanagement und Governance
17:30 - 18:00	Integration der Krypto-Informationen von IBM System Z in das zentrale Crypto Inventory von GCM
18:00 - 18:30	Integration in bestehende Plattformen: HashiCorp Vault, OpenShift und Certificate Lifecycle Management
18:30 - 19:00	IBM Quantum Safe Remediator
19:00 - 20:00	Get-together & Ausklang

Quantencomputer und Kryptographie

Risiken, Auswirkungen auf heutige Verfahren und die
Einordnung der BSI TR-02102

Agenda

01 Das Risiko

Was Quantencomputer können,
was sie noch nicht können und
wann sie relevant werden

02 Die Auswirkungen

Was an heutiger Kryptographie
bricht – und was nicht

03 Die Relevanz

Für Security, Compliance und IT-
Betrieb

04 Die Einordnung

Das BSI, die TR-02102 und die
Fristen bis 2035

05 Das Zielbild

Was konkret umgesetzt wird

01

Das Risiko

Der Angriff kann längst stattgefunden haben

Verschlüsselte Daten, die heute mitgeschnitten werden, lassen sich später entschlüsseln. Was 2040 noch vertraulich sein muss, ist deshalb heute schon ein Problem.

Was ein Quantencomputer anders macht

Nicht schneller – anders

- Ein Quantencomputer ist kein schnellerer Rechner. Er löst eine kleine Klasse mathematischer Probleme auf grundsätzlich andere Weise. Genau auf diesen Problemen beruht die heutige asymmetrische Kryptographie.

Shor bricht die Vertrauensbasis

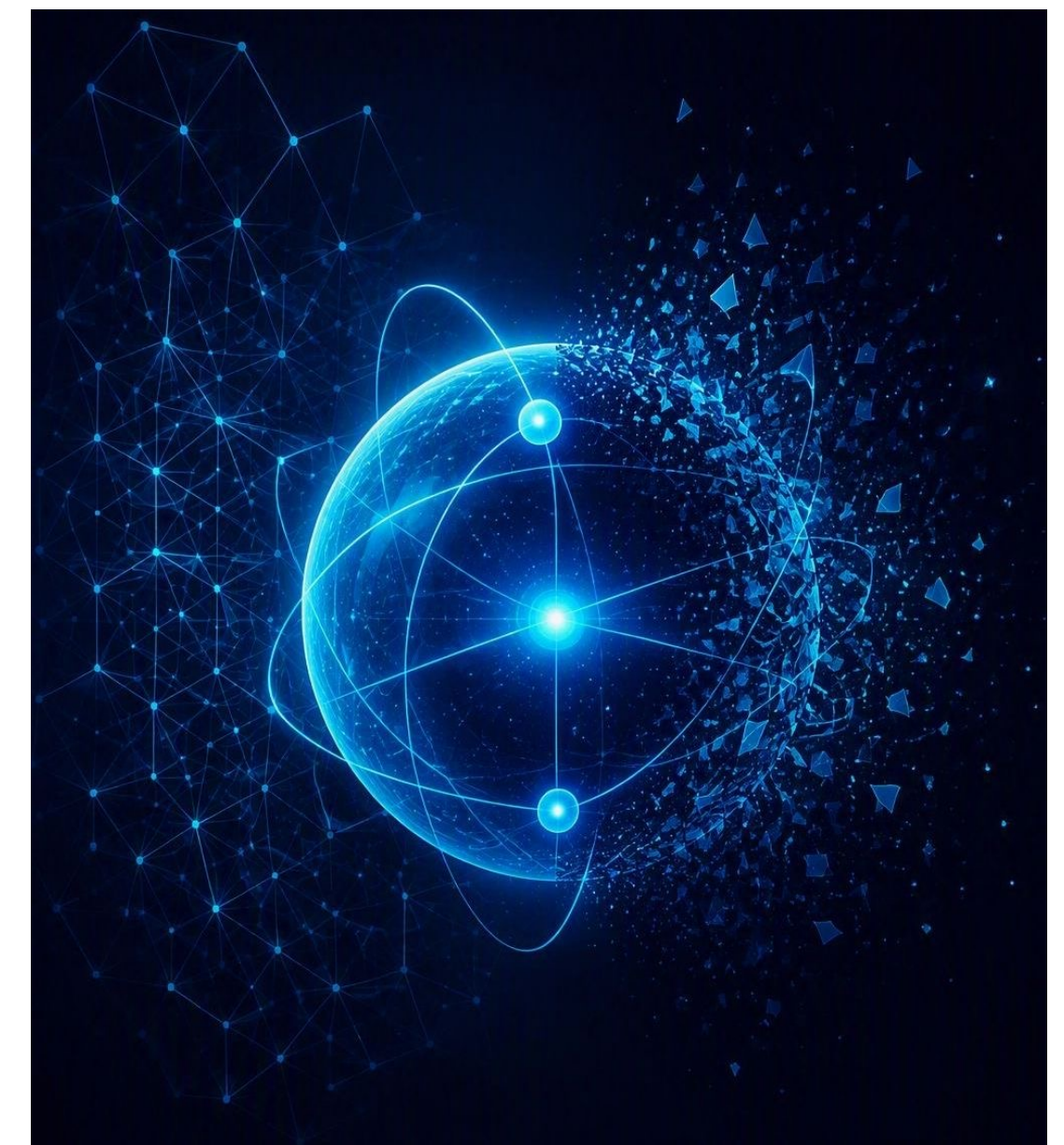
- Der Shor-Algorithmus löst Faktorisierung und diskrete Logarithmen. Damit fallen RSA, Diffie-Hellman und elliptische Kurven – nicht teilweise, sondern vollständig.

Grover kratzt nur an der Oberfläche

- Für symmetrische Verfahren bringt Grover lediglich eine quadratische Beschleunigung, deren praktischer Nutzen offen ist. AES bleibt nutzbar – mit längeren Schlüsseln.

Der eigentliche Engpass

- Qubits sind extrem fehleranfällig. Erst Fehlerkorrektur macht sie rechenfähig, und sie kostet ein Vielfaches an Hardware. Daran entscheidet sich der Zeitpunkt.



Wo
Quantencomputer
heute stehen

120

Qubits im leistungsfähigsten IBM-Prozessor

- IBM Quantum Nighthawk, November 2025.
Zuverlässig bis rund 5.000 Rechenschritte. Das sind physische Qubits – für Kryptanalyse zählen logische, fehlerkorrigierte Qubits.

480 ns

Latenz der Fehlerkorrektur

- Auf dem Loon-Chip berechnet ein Echtzeit-Decoder die Korrektur in unter 480 Nanosekunden – ein Jahr früher als geplant. Der Engpass löst sich schneller als erwartet.

**Quantenvorteil ist noch nicht
Kryptorelevanz – aber er
zeigt, dass die
Fehlerkorrektur funktioniert.**

0

Systeme, die Kryptographie brechen können

- Der im Juli 2026 belegte Quantenvorteil betrifft die Simulation von Materialien, nicht die Kryptanalyse. Zwischen heute und einem solchen System liegen drei bis vier Größenordnungen.

Wann wird es relevant?

Quelle	Aussage
BSI · Studie „Entwicklungsstand Quantencomputer“, Dezember 2025	Ein kryptographisch relevanter Quantencomputer bis 2040 erscheint realistisch. Die Fehlerkorrektur ist experimentell nachgewiesen; neue Codes könnten den Zeitplan beschleunigen.
Global Risk Institute · Quantum Threat Timeline 2025	Befragung von 26 Fachleuten: 28 bis 49 Prozent Wahrscheinlichkeit innerhalb von zehn Jahren – der höchste Wert in sieben Jahren. 18 von 26 sehen mindestens 50 Prozent innerhalb von 15 Jahren.
Google Quantum AI · Mai 2025	Der geschätzte Aufwand für einen Angriff auf RSA-2048 ist von 20 Millionen Qubits (2019) auf unter eine Million gefallen. Der Fortschritt kam aus besseren Algorithmen, nicht aus schnellerer Hardware.
IBM Quantum Roadmap	Starling 2029: 200 logische Qubits. Blue Jay ab 2033: 2.000 logische Qubits. Noch nicht das, was für einen Angriff nötig wäre – aber eine Größenordnung, die man vor fünf Jahren nicht datiert hätte.
Die ehrliche Antwort	Niemand weiß es. Für die Entscheidung, die jetzt ansteht, ist das aber auch nicht nötig.

02

Die Auswirkungen auf heutige Verfahren

Was bricht – und was hält

Bricht vollständig: asymmetrische Verfahren

- Betroffen sind RSA, Diffie-Hellman, ECDH und ECDSA – also alle Verfahren, die Schlüssel austauschen oder Identitäten belegen.
- Damit steht alles zur Disposition, was auf ihnen aufsetzt: TLS-Verbindungen, VPN-Aufbau, SSH-Anmeldung, Zertifikate und digitale Signaturen.
- Das Sicherheitsniveau fällt auf null – nicht auf die Hälfte. Es gibt keinen Zwischenzustand, in dem man mit längeren Schlüsseln weiterarbeiten könnte.

Hält mit Anpassung: symmetrische Verfahren

- AES bleibt nutzbar. Für langfristigen Schutzbedarf empfiehlt das BSI AES-256 statt AES-128.
- Hashfunktionen bleiben nutzbar. SHA-256 ist das Minimum, SHA-384 oder SHA-512 bei hohem oder langfristigem Schutzbedarf.
- Hier genügt eine Parameteranpassung – kein Verfahrenswechsel, keine Migration.
- Die gute Nachricht: Der Aufwand konzentriert sich damit auf asymmetrische Verfahren, PKI und Protokolle.

Wo Kryptographie überall steckt

Web und Schnittstellen

- Jede HTTPS-Verbindung, jede API, jeder Cloud-Dienst. Hier ist die Umstellung am weitesten fortgeschritten und betrifft überwiegend Konfiguration.

Standortkopplung und Fernzugriff

- VPN-Gateways und Remote-Zugänge. Betrifft Hardware mit langen Austauschzyklen: Was heute beschafft wird, ist 2031 noch im Einsatz.

Administrative Zugänge

- SSH-Schlüssel, oft über Jahre unverändert und in den seltensten Fällen vollständig inventarisiert.

Identitäten und Zertifikate

- Die PKI ist die Vertrauensbasis des gesamten Unternehmens. Längster Vorlauf, größter Aufwand, geringste Sichtbarkeit im Tagesgeschäft.

Software und Updates

- Code- und Firmware-Signaturen. Wer sie brechen kann, kann manipulierte Updates in die eigene Lieferkette einspeisen.

Gespeicherte Daten und Backups

- Häufig mit der längsten Aufbewahrungsfrist im Haus – und damit dem längsten Schutzbedarf. Wird in Migrationsplänen regelmäßig übersehen.

Zwei Uhren, die unterschiedlich ticken

Vertraulichkeit – die Uhr läuft rückwärts

- Verschlüsselter Verkehr kann heute aufgezeichnet und später entschlüsselt werden.
- Der Schaden entsteht rückwirkend: Er trifft Daten, die längst übertragen wurden und über die niemand mehr Kontrolle hat.
- Deshalb die frühere Frist: Ende 2031 – und Ende 2030 bei sehr hohem Schutzbedarf.
- Handlungslogik: Priorität nach Schutzdauer der Daten, nicht nach Systemgröße.

Authentizität – die Uhr läuft vorwärts

- Eine Signatur wird nicht rückwirkend wertlos. Sie verliert ihre Aussagekraft erst in dem Moment, in dem ein Quantencomputer existiert.
- Dafür dauert die Umstellung am längsten: Zertifikatshierarchien, Vertrauensanker in Geräten und Betriebssystemen, Signaturformate, Archive.
- Deshalb die spätere – aber nicht entspanntere – Frist: Ende 2035.
- Handlungslogik: Priorität nach Lebensdauer der Systeme.

03

Relevanz für Security,
Compliance und IT-Betrieb

Drei Blickwinkel auf dasselbe Thema

Security

- Es geht nicht um einen neuen Angriffsvektor, sondern um den Wegfall einer Annahme, auf der sämtliche bestehenden Kontrollen aufsetzen. Kryptographie ist Infrastruktur, kein Feature.

Compliance

- NIS-2 verlangt Risikomaßnahmen nach dem Stand der Technik, ausdrücklich einschließlich Kryptographie. Die TR-02102 definiert diesen Stand seit Januar 2026 neu – damit altern bestehende Krypto-Richtlinien.

IT-Betrieb

- Hier liegt die eigentliche Arbeit: inventarisieren, Konfigurationen zentralisieren, Zertifikatslaufzeiten verkürzen, Lieferantenfähigkeit prüfen. Nichts davon lässt sich kurzfristig nachholen.

Was die drei verbindet

- Ohne ein belastbares Krypto-Inventar kann keiner der drei seine Aufgabe erfüllen. Das ist der erste Schritt – und der einzige, der sofort startbar ist.

Die Compliance-Landschaft

Vorgabe	Seit / ab	Was daraus folgt
NIS-2 · BSIG	06.12.2025	Rund 29.500 statt bisher 4.500 Einrichtungen. Risikomanagement nach Stand der Technik, ausdrücklich einschließlich Kryptographie. Die Geschäftsleitung billigt, überwacht und haftet.
BSI TR-02102	23.01.2026	Definiert den Stand der Technik – mit festen Enddaten für klassische asymmetrische Verfahren.
DORA	17.01.2025	Finanzsektor: verpflichtende Kryptographie-Richtlinie, einschließlich eines Verfahrens zur Aktualisierung bei kryptographischem Fortschritt.
Cyber Resilience Act	09/2026 und 12/2027	Hersteller müssen Sicherheitsupdates über den gesamten Supportzeitraum liefern. Ohne quantensicheren Upgrade-Pfad ist das nicht erfüllbar.
KRITIS-Dachgesetz	17.03.2026	Resilienznachweise für Betreiber kritischer Anlagen – häufig der Anlass, bei dem das Krypto-Inventar mit erhoben wird.
DSGVO Art. 32	seit 2018	„Stand der Technik“ als Maßstab im Schadens- und Bußgeldfall.

Wann ist es zu spät?

10–30

Jahre Schutzdauer

- Wie lange müssen die Daten vertraulich bleiben? Konstruktionsdaten, Verträge, Personal- und Gesundheitsdaten liegen typischerweise in dieser Spanne.

5–10

Jahre Migrationsdauer

- Wie lange dauert die Umstellung? Für PKI, eingebettete Systeme und gewachsene Anwendungslandschaften ist das realistisch, nicht pessimistisch.

Schutzdauer plus Migrationsdauer übersteigt bereits heute die verbleibende Zeit. Man muss den dritten Wert nicht kennen, um zu handeln.

?

Jahre bis zum Quantencomputer

- Nicht planbar, nur abschätzbar. Das BSI hält 2040 für realistisch – das sind rund 14 Jahre.

04

Einordnung: das BSI und
die TR-02102

Wie verbindlich ist eine Technische Richtlinie?

Wer das BSI ist

– Cyber-Sicherheitsbehörde des Bundes, gegründet 1991, Rechtsgrundlage ist das BSI-Gesetz. Setzt Standards, zertifiziert Produkte und beaufsichtigt seit NIS-2 rund 29.500 Einrichtungen. Eigene Algorithmen standardisiert es nicht – es bewertet, wählt aus und parametrisiert.

Verbindlich

– Für die Bundesverwaltung, für Produkte zur Verarbeitung von Verschlusssachen ab VS-NfD und als Prüfmaßstab in Zertifizierungs- und Zulassungsverfahren des BSI.

De facto verbindlich

– Über den Begriff „Stand der Technik“ in NIS-2 und BSIG, DSGVO Art. 32, DORA und TISAX – und zunehmend über Kundenverträge und Audits.

Empfehlung

– Für die übrige Wirtschaft formal unverbindlich, aber die am besten begründete und international anerkannte Referenz für Algorithmen und Schlüssellängen.

Die TR-02102 und was sich 2026 geändert hat

Vier Teile

- Teil 1: Verfahren und Schlüssellängen – das Referenzdokument. Teile 2 bis 4: TLS, IPsec und IKEv2, SSH. Alle in Version 2026-01 vom Januar 2026.

Sicherheitsniveau mindestens 120 Bit

- Daraus folgen die Schlüssellängen: RSA und Finite-Field-DH ab 3000 Bit, elliptische Kurven ab 250 Bit, SHA-256 als kleinste empfohlene Hashfunktion.

Prognosehorizont Ende 2032

- Die TR trifft ausdrücklich keine Aussagen darüber hinaus – Vorhersagen über sechs bis sieben Jahre gelten als nicht belastbar. Fortschreibung jährlich im Januar.

Neu: die Abkündigung

- Erstmals wird die alleinige Nutzung klassischer asymmetrischer Verfahren abgekündigt – mit festen Enddaten statt allgemeiner Warnungen.

Neu: Hybrid als Regelfall

- Quantensichere Verfahren sollen mit klassischen kombiniert werden – für die Schlüsseleinigung und für Signaturen. Rein hash-basierte Signaturen dürfen allein stehen.

Neu: Aufräumen im Bestand

- RSA-Signaturen mit PKCS#1-v1.5-Padding abgekündigt, TLS 1.2 endet 2031, DSA und DHE-Cipher-Suites laufen 2029 aus.

Die Fristen im Detail

Frist	Was endet	Fundstelle
Ende 2030	Alleiniger Einsatz klassischer Schlüsseleinigung bei sehr hohem Schutzbedarf	TR-02102-1, Kap. 2.1 (gemeinsame Empfehlung mit europäischen Partnerbehörden)
Ende 2031	Alleiniger Einsatz klassischer Schlüsseleinigung: RSA, DH, ECDH – danach nur noch hybrid mit einem quantensicheren Verfahren	TR-02102-1, Kap. 2.1 und 2.3, Tab. 2.2
Ende 2031	TLS 1.2 – dafür sind keine quantensicheren Schlüsseleinigungsverfahren zu erwarten	TR-02102-2, Tab. 2
Ende 2035	Alleiniger Einsatz klassischer Signaturverfahren: RSA, ECDSA	TR-02102-1, Kap. 2.1 und 5.3; folgt der EU-Roadmap
2029	DSA sowie DHE-Cipher-Suites in TLS	TR-02102-1, Rem. 5.5; TR-02102-2
bereits heute	RSA und DH unter 3000 Bit, EC unter 250 Bit, PKCS#1 v1.5 als Signaturpadding, SHA-1, 3DES, TLS bis 1.1	TR-02102-1, Kap. 1.1; TR-02102-2, Änderungshistorie 2026-01

BSI und NIST – wo sie auseinandergehen

Aspekt	BSI	NIST und NSA
Rolle	Bewertet, wählt aus und parametrisiert; erteilt Zulassungen. Standardisiert keine eigenen Algorithmen.	Standardisiert die Algorithmen selbst: FIPS 203, 204 und 205, final seit August 2024. Nachweis über FIPS-140-3-Validierung.
Auswahl	Nur die höheren Sicherheitsstufen; zusätzlich konservative Alternativen wie FrodoKEM und Classic McEliece.	Breiteres Spektrum, auch die niedrigste Sicherheitsstufe. FrodoKEM ausdrücklich nicht standardisiert.
Hybride Verfahren	Regelfall – quantensicher und klassisch werden kombiniert, für Schlüsseleinigung und für Signaturen.	Nicht gefordert. Die NSA lässt Hybrid nur als Übergang zu; Ziel ist reines PQC.
Fristen	Schlüsseleinigung Ende 2031, bei sehr hohem Schutzbedarf Ende 2030; Signaturen Ende 2035.	„Deprecated“ nach 2030, „disallowed“ nach 2035. Für US-Bundessysteme teilweise früher.

05

Das Zielbild: was konkret
umgestellt wird

Das technische Zielbild

TLS

- TLS 1.3 mit hybrider Schlüsseleinigung. Das BSI beabsichtigt SecP256r1MLKEM768 und SecP384r1MLKEM1024, sobald der IETF-Entwurf RFC wird; verbreitet ist heute X25519MLKEM768.

VPN und IPsec

- Ausschließlich IKEv2. Zusätzlicher Schlüsselaustausch nach RFC 9370 mit ML-KEM-768 oder ML-KEM-1024.

SSH

- OpenSSH ab Version 9.9: mlkem768nistp256-sha256 und mlkem1024nistp384-sha384.

PKI und Signaturen

- ML-DSA-65 oder -87, alternativ SLH-DSA – jeweils hybrid mit einem klassischen Signaturverfahren. Längster Vorlauf im gesamten Programm.

Code- und Firmware-Signatur

- XMSS oder LMS. Hash-basierte Verfahren dürfen ausnahmsweise ohne Hybridisierung stehen; Voraussetzung ist sicheres Zustandsmanagement.

Daten und Backups

- AES-256, dazu SHA-384 oder SHA-512 bei hohem oder langfristigem Schutzbedarf. Schlüsselkombination hybrid über CatKDF oder KeyCombine.

Vier Schritte, die jetzt zählen

1 · Inventarisieren

– Algorithmen, Schlüssel, Zertifikate, Protokollversionen und Bibliotheken erfassen – automatisiert und wiederholbar, nicht per Fragebogen.

2 · Priorisieren

– Nach Schutzdauer der Daten und Lebensdauer der Systeme sortieren. Langlebige Vertraulichkeit und langlebige Geräte zuerst.

3 · Agilität herstellen

– Algorithmen konfigurierbar statt hartkodiert, zentrale Krypto-Policy, kürzere Zertifikatslaufzeiten, Beschaffung fordert quantensichere Upgrade-Pfade.

4 · Hybrid migrieren

– Zuerst die Schlüsseleinigung in TLS, SSH und IKEv2, danach Signaturen und PKI. Jährlicher Abgleich mit der neuen TR-02102 im Januar.

Was Sie mitnehmen sollten

Das Risiko ist die Zeit, nicht die Maschine

- Schutzdauer plus Migrationsdauer übersteigt bereits heute die verbleibende Frist. Ob der Quantencomputer 2032 oder 2040 kommt, ändert daran nichts.

Asymmetrisch ist das Problem

- Symmetrische Verfahren brauchen nur längere Schlüssel. Der Aufwand liegt bei PKI, Protokollen und Zertifikaten – nicht bei der Verschlüsselung selbst.

Die Fristen stehen

- Schlüsseleinigung Ende 2031, sehr hoher Schutzbedarf Ende 2030, Signaturen Ende 2035 – in einer Technischen Richtlinie, nicht in einem Positionspapier.

Der erste Schritt ist klein

- Ein belastbares Krypto-Inventar. Ohne das ist jede weitere Planung Spekulation – und mit ihm ist die Risikobewertung und damit Priorisierung meist in Wochen erledigt.

Quellen

BSI

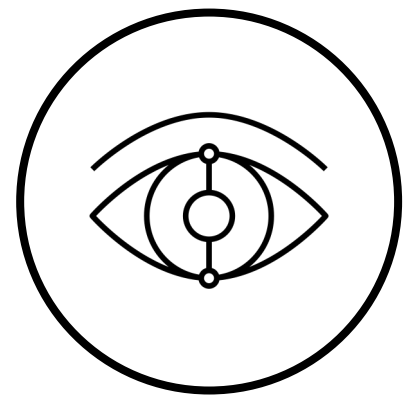
- TR-02102-1: Kryptographische Verfahren – Empfehlungen und Schlüssellängen, Version 2026-01 vom 23.01.2026
- TR-02102-2/-3/-4: TLS, IPsec und IKEv2, SSH, jeweils Version 2026-01 vom 27.01.2026
- Pressemitteilung „BSI empfiehlt Ende klassischer asymmetrischer Verschlüsselungsverfahren“, 11.02.2026
- Studie „Entwicklungsstand Quantencomputer“, Version 2.2, Dezember 2025
- Securing Tomorrow, Today – gemeinsame Erklärung von Partnerbehörden aus 18 EU-Staaten, 2024
- NIS-2-Umsetzungsgesetz, in Kraft seit 06.12.2025; KRITIS-Dachgesetz, in Kraft seit 17.03.2026

International

- NIST FIPS 203 (ML-KEM), FIPS 204 (ML-DSA), FIPS 205 (SLH-DSA), 13.08.2024
- NIST IR 8547: Transition to Post-Quantum Cryptography Standards (Entwurf)
- NIST SP 800-227: Recommendations for Key Encapsulation Mechanisms, 2025
- NSA: Commercial National Security Algorithm Suite 2.0
- EU NIS Cooperation Group: A Coordinated Implementation Roadmap for the Transition to PQC, 23.06.2025
- Executive Order 14412 „Securing the Nation Against Advanced Cryptographic Attacks“, 22.06.2026
- C. Gidney: How to factor 2048 bit RSA integers with less than a million noisy qubits, arXiv:2505.15917, 2025
- Global Risk Institute: Quantum Threat Timeline Report 2025
- ETSI TS 103 744 (CatKDF); IBM Quantum Roadmap und Ankündigungen 11/2025 und 07/2026

IBM Guardium Cryptography Manager

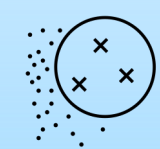
Protecting today. Preparing for tomorrow.



Discover and Inventory



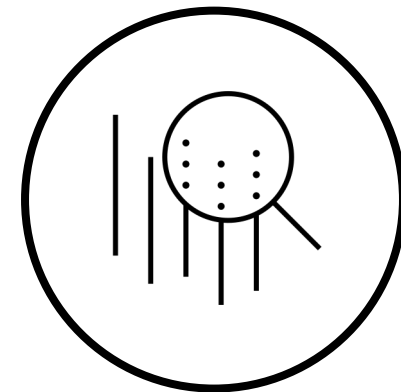
Identify cryptographic objects and IT assets



Detect unknown or shadow cryptography



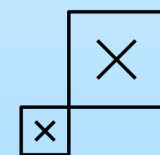
Map dependencies, ownership, and usage



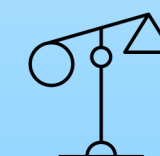
Assess and Comply



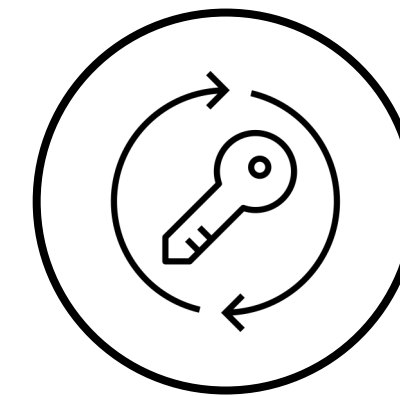
Assess post-quantum cryptography risk



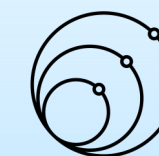
Flag outdated or vulnerable algorithms



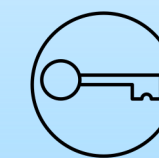
Generate CSV exports for audits



Manage Lifecycle



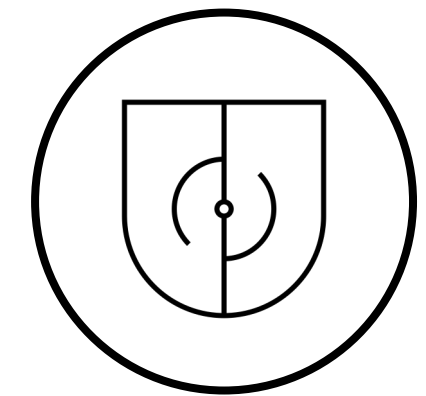
Centralize lifecycle operations in one tool



Automate key generation and certificate renewal



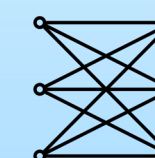
Enforce consistent policies across the organization



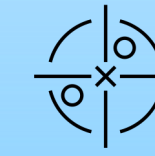
Protect and Adapt



Utilize encryption to protect sensitive data



Assess the efficiency and feasibility of PQC algorithms



Protect against "harvest now, decrypt later" attacks

Quantum-safe technologies

Cryptography management for the quantum era



IBM Quantum Safe Explorer

Discover cryptography and vulnerabilities in custom applications.

Obtain insights on code-level risks to guide remediation efforts.

Remediate at-risk cryptography by pinpointing precise location in code.



IBM Guardium Quantum Safe*

Gain visibility into cryptography use across the enterprise network and applications.

Enable faster compliance by applying internal and regulatory policies.

Prioritize vulnerabilities, based on policies, to accelerate remediation actions and track progress.



IBM Quantum Safe Remediator

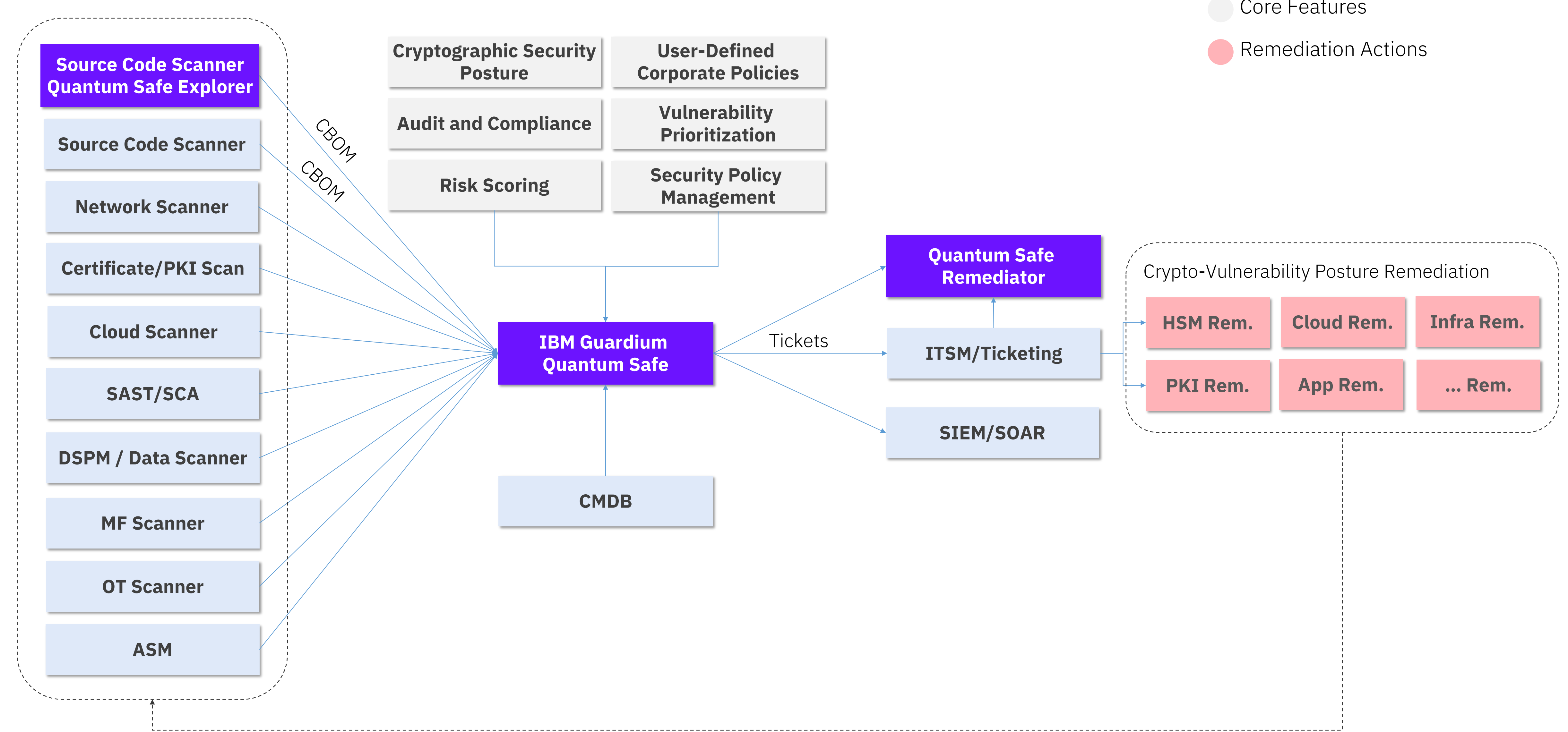
Protect application and network endpoints today without any application changes.

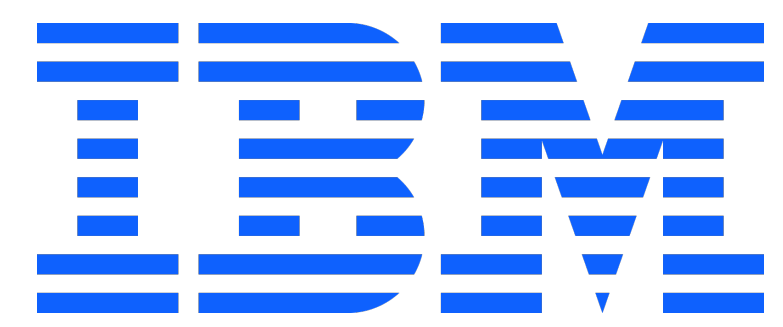
Evaluate the performance of quantum-safe cryptographic algorithms

Mitigate “Harvest Now, Decrypt Later” scenarios

IBM Quantum-Safe Technologies (Crypto Agility)

Cryptography management for the quantum era





Backup

NIS-2-Betroffenheit,
Trigger und Qualifizierung

Wer ist in Deutschland NIS-2- reguliert?

Kategorie	Wer	Schwelle
Betreiber kritischer Anlagen	KRITIS-Anlagen oberhalb der Schwellenwerte der BSI-KritisV – Versorgungsgrad ab 500.000 Personen	größenunabhängig
Besonders wichtige Einrichtungen § 28 Abs. 1 BSIG	Sektoren der Anlage 1	ab 250 Beschäftigte oder über 50 Mio. € Umsatz und über 43 Mio. € Bilanzsumme
Wichtige Einrichtungen § 28 Abs. 2 BSIG	Sektoren der Anlagen 1 und 2, die die obere Schwelle nicht erreichen	ab 50 Beschäftigte oder über 10 Mio. € Umsatz und Bilanzsumme
Unabhängig von der Größe	Qualifizierte Vertrauensdiensteanbieter, TLD-Namenregister, DNS-Dienste, Anbieter öffentlicher TK-Netze und -Dienste	keine Schwelle
Bundesverwaltung § 29 BSIG	Bundesbehörden und öffentlich-rechtliche IT-Dienstleister des Bundes	keine Schwelle
Nicht direkt erfasst	Länder und Kommunen – nur über Landesrecht; einzelne Länder haben eigene Gesetze in Arbeit	–

Die 18 regulierten Sektoren

Anlage 1 – 11 Sektoren hoher Kritikalität

- Energie: Strom, Gas, Erdöl, Fernwärme, Wasserstoff
- Transport und Verkehr: Luft, Schiene, Schifffahrt, Straße
- Bankwesen
- Finanzmarktinfrastrukturen
- Gesundheitswesen: Versorger, Labore, Pharma, Hersteller von Medizinprodukten
- Trinkwasser
- Abwasser
- Digitale Infrastruktur: Rechenzentren, Cloud, CDN, TK-Netze, Vertrauensdienste
- Verwaltung von IKT-Diensten (B2B): Managed Service und Managed Security Provider
- Öffentliche Verwaltung – der Bund über § 29 BSIG
- Weltraum: Betreiber von Bodeninfrastrukturen

Anlage 2 – 7 sonstige kritische Sektoren

- Post- und Kurierdienste
- Abfallbewirtschaftung
- Chemie: Herstellung und Handel mit chemischen Stoffen
- Lebensmittel: Produktion, Verarbeitung, Vertrieb
- Verarbeitendes Gewerbe: Medizinprodukte, DV-Geräte und Elektronik, elektrische Ausrüstungen, Maschinenbau, Kfz und Teile, sonstiger Fahrzeugbau
- Digitale Dienste: Online-Marktplätze, Suchmaschinen, soziale Netzwerke
- Forschungseinrichtungen

Der Sektor „Verarbeitendes Gewerbe“ ist der Grund, warum der klassische deutsche Mittelstand erstmals reguliert ist.

Stand der Umsetzung

29.500

betroffene Einrichtungen

- Vor NIS-2 waren es rund 4.500. Die Zahl stammt aus der Gesetzesbegründung und ist eine Schätzung – die tatsächliche Betroffenheit muss jede Einrichtung selbst feststellen.

18.500

registriert bis zum 31.07.2026

- Die gesetzliche Frist lief am 6. März 2026 ab. Weil nur rund 11.500 Einrichtungen registriert waren, hat das BSI eine Nachfrist bis Ende Juli 2026 eingeräumt.

**Bußgeldrahmen: bis 500.000
€ für die fehlende
Registrierung, bis 10 Mio. €
oder 2 % des weltweiten
Jahresumsatzes für
mangelhaftes
Risikomanagement.**

11.000

fehlen weiterhin

- Gut ein Drittel. Die Phase der Nachsicht ist beendet – die Registrierungspflicht besteht unverändert fort und wird laufend verletzt.

Die Pflichten – und wo Kryptographie sitzt

Registrierung · § 33

- Binnen drei Monaten nach Eintritt der Betroffenheit im BSI-Portal. Für am 6.12.2025 erfasste Einrichtungen lief die Frist am 6. März 2026 ab, die Nachfrist des BSI am 31. Juli 2026.

Risikomanagement · § 30 und § 31

- Dokumentierte Maßnahmen nach dem Stand der Technik
 - ausdrücklich einschließlich Konzepten für Kryptographie und Verschlüsselung sowie Sicherheit der Lieferkette. Hier hängt PQC.

Meldung · § 32

- Erhebliche Sicherheitsvorfälle:
 - Erstmeldung binnen 24 Stunden, Aktualisierung binnen 72 Stunden, Abschlussmeldung binnen eines Monats.

Geschäftsleitung · § 38

- Billigung und Überwachung der Maßnahmen, Teilnahme an Schulungen, Innenhaftung nach GmbHG und AktG. Betreiber kritischer Anlagen weisen die Umsetzung zusätzlich alle drei Jahre nach (§ 39).

Trigger-Landkarte für PQC

		Regulierung – NIS-2 und BSIG seit 06.12.2025 · KRITIS-Dachgesetz seit 17.03.2026 · DORA im Finanzsektor · Cyber Resilience Act ab 09/2026 und 12/2027 · eIDAS 2.0 und EUDI-Wallet · DSGVO Art. 32.	Lieferkette und Vergabe – Kundenfragebögen und Ausschreibungen · TISAX im Automotive-Umfeld · Druck aus der US-Lieferkette über die Executive Order 14412 · Bundesbeschaffung nach TR-03116 · VS-NfD-Zulassung.
Umsetzungsfenster – PKI-Modernisierung oder Root-CA-Wechsel · HSM-Refresh · Zero Trust und SASE · Cloud-Migration · Design-Freeze bei Produkten mit langer Lebensdauer.	Prüfungsdruck – Interne Revision · Wirtschaftsprüfer im Rahmen der IT-Prüfung · Pentest-Befunde mit SHA-1, RSA-2048 oder TLS 1.0/1.1 – alles bereits heute nicht TR-konform.	Langzeitvertraulichkeit – Konstruktionsdaten, Rezepturen, Patentanmeldungen vor Veröffentlichung, Personal- und Gesundheitsdaten, Langzeitarchive. „Store now, decrypt later“ wird hier konkret.	Branchenvorgaben – Smart Meter Gateway nach TR-03109 · gematik gemSpec_Krypt in der Telematikinfrastruktur · UN R155 und ISO/SAE 21434 im Automotive · TR-03116 für Bundesprojekte.

Qualifizierung in drei Fragen

1

„Sind Sie NIS-2-reguliert – und wann ist Ihr nächster Nachweis fällig?“

- Prüft, ob Regulierungsdruck mit Datum vorhanden ist. Wer noch nicht registriert ist, hat ein akutes Thema.

2

„Hat Sie in den letzten zwölf Monaten ein Kunde oder Auditor nach Kryptographie oder PQC gefragt?“

- Prüft den Außendruck aus Lieferkette und Prüfungswesen. Dieser Trigger erzeugt am zuverlässigsten Budget.

Zwei von drei Ja bedeuten in der Regel ein Projekt innerhalb von zwölf Monaten. Null von drei: mit der Inventarisierung einsteigen – sie erzeugt den Trigger selbst.

3

„Steht in den nächsten 24 Monaten etwas an der PKI oder an den HSMs an?“

- Prüft, ob ein Umsetzungsfenster offen ist. PQC bekommt selten eigenes Budget – es wird angehängt.

